Merged vulnerability report
21 finding(s)

Finding 1
  ID: 1
  Title: Cookie without SameSite Attribute
  Severity: Low
  Confidence: Medium
  Scanners: ZAP
  Affected: http://127.0.0.1:4280/security.php (GET)
  Description: A cookie has been set without the SameSite attribute, which means that the cookie can
      be sent as a result of a 'cross-site' request. The SameSite attribute is an effective counter
      measure to cross-site request forgery, cross-site script inclusion, and timing attacks.
  Solution: Ensure that the SameSite attribute is set to either 'lax' or ideally 'strict' for all
      cookies.
  CVE: -
  CWE: CWE-1275
  References: https://datatracker.ietf.org/doc/html/draft-ietf-httpbis-cookie-same-site
  Also Reported As: -
  Composite Score: 2.5

Finding 2
  ID: 2
  Title: Content Security Policy (CSP) Header Not Set
  Severity: Medium
  Confidence: High
  Scanners: ZAP
  Affected:
    - http://127.0.0.1:4280/login.php (GET)
    - http://127.0.0.1:4280/security.php (GET)
    - http://127.0.0.1:4280/sitemap.xml (GET)
  Description: Content Security Policy (CSP) is an added layer of security that helps to detect and
      mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection
      attacks. These attacks are used for everything from data theft to site defacement or
      distribution of malware. CSP provides a set of standard HTTP headers that allow website owners
      to declare approved sources of content that browsers should be allowed to load on that page —
      covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as
      Java applets, ActiveX, audio and video files.
  Solution: Ensure that your web server, application server, load balancer, etc. is configured to
      set the Content-Security-Policy header.
  CVE: -
  CWE: CWE-693
  References:
    - https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP
    - https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html
    - https://www.w3.org/TR/CSP/
    - https://w3c.github.io/webappsec-csp/
    - https://web.dev/articles/csp
    - https://caniuse.com/#feat=contentsecuritypolicy
    - https://content-security-policy.com/
  Also Reported As: -
  Composite Score: 0.10585

Finding 3
  ID: 3
  Title: X-Content-Type-Options Header Missing
  Severity: Low
  Confidence: Medium
  Scanners: ZAP
  Affected:
    - http://127.0.0.1:4280/dvwa/css/login.css (GET)
    - http://127.0.0.1:4280/dvwa/images/login_logo.png (GET)
    - http://127.0.0.1:4280/login.php (GET)
    - http://127.0.0.1:4280/robots.txt (GET)
    - http://127.0.0.1:4280/security.php (GET)
  Description: The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This
      allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response
      body, potentially causing the response body to be interpreted and displayed as a content type
      other than the declared content type. Current (early 2014) and legacy versions of Firefox will
      use the declared content type (if one is set), rather than performing MIME-sniffing.
  Solution: Ensure that the application/web server sets the Content-Type header appropriately, and
      that it sets the X-Content-Type-Options header to 'nosniff' for all web pages.
      If possible, ensure that the end user uses a standards-compliant and modern web browser that
      does not perform MIME-sniffing at all, or that can be directed by the web application/web
      server to not perform MIME-sniffing.

```
  CVE: -
  CWE: CWE-693
  References:
    - https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/com
      patibility/gg622941(v=vs.85)
    - https://owasp.org/www-community/Security_Headers
  Also Reported As: -
  Composite Score: 0.10585

Finding 4
  ID: 4
  Title: Missing Anti-clickjacking Header
  Severity: Medium
  Confidence: Medium
  Scanners:
    - Nikto
    - ZAP
  Affected:
    - localhost:80/ (GET)
    - http://127.0.0.1:4280/login.php (GET)
    - http://127.0.0.1:4280/security.php (GET)
  Description: The response does not protect against 'ClickJacking' attacks. It should include
      either Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.
  Solution: Modern Web browsers support the Content-Security-Policy and X-Frame-Options HTTP
      headers. Ensure one of them is set on all web pages returned by your site/app.
      If you expect the page to be framed only by pages on your server (e.g. it's part of a
      FRAMESET) then you'll want to use SAMEORIGIN, otherwise if you never expect the page to be
      framed, you should use DENY. Alternatively consider implementing Content Security Policy's
      "frame-ancestors" directive.
  CVE: -
  CWE: CWE-1021
  References: https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options
  Also Reported As: X-Frame-Options header is deprecated and was replaced with the
      Content-Security-Policy HTTP header with the frame-ancestors directive.
  Composite Score: 0.04938

Finding 5
  ID: 5
  Title: In Page Banner Information Leak
  Severity: Low
  Confidence: High
  Scanners: ZAP
  Affected: http://127.0.0.1:4280/sitemap.xml (GET)
  Description: The server returned a version banner string in the response content. Such information
      leaks may allow attackers to further target specific issues impacting the product and version
      in use.
  Solution: Configure the server to prevent such information leaks. For example:
      Under Tomcat this is done via the "server" directive and implementation of custom error pages.
      Under Apache this is done via the "ServerSignature" and "ServerTokens" directives.
  CVE: -
  CWE: CWE-497
  References: https://owasp.org/www-project-web-security-testing-guide/v41/4-Web_Application_Securit
      y_Testing/08-Testing_for_Error_Handling/
  Also Reported As: -
  Composite Score: 0.01426

Finding 6
  ID: 6
  Title: Server Leaks Version Information via "Server" HTTP Response Header Field
  Severity: Low
  Confidence: High
  Scanners: ZAP
  Affected:
    - http://127.0.0.1:4280/ (GET)
    - http://127.0.0.1:4280/login.php (GET)
    - http://127.0.0.1:4280/security.php (GET)
    - http://127.0.0.1:4280/login.php (POST)
    - http://127.0.0.1:4280/dvwa/css/login.css (GET)
    - http://127.0.0.1:4280/dvwa/images/login_logo.png (GET)
    - http://127.0.0.1:4280/robots.txt (GET)
  Description: The web/application server is leaking information via one or more "X-Powered-By" HTTP
      response headers. Access to such information may facilitate attackers identifying other
      frameworks/components your web application is reliant upon and the vulnerabilities such
      components may be subject to.
  Solution: Ensure that your web server, application server, load balancer, etc. is configured to
```

```
      suppress "X-Powered-By" headers.
  CVE: -
  CWE: CWE-497
  References:
    - https://owasp.org/www-project-web-security-testing-guide/v42/4-Web_Application_Security_Testin
      g/01-Information_Gathering/08-Fingerprint_Web_Application_Framework
    - https://www.troyhunt.com/shhh-dont-let-your-response-headers/
    - https://httpd.apache.org/docs/current/mod/core.html#servertokens
    - https://learn.microsoft.com/en-us/previous-versions/msp-n-p/ff648552(v=pandp.10)
  Also Reported As: Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)
  Composite Score: 0.01426

Finding 7
  ID: 7
  Title: Authentication Request Identified
  Severity: Informational
  Confidence: High
  Scanners: ZAP
  Affected: http://127.0.0.1:4280/login.php (POST)
  Description: The given request has been identified as an authentication request. The 'Other Info'
      field contains a set of key=value lines which identify any relevant fields. If the request is
      in a context which has an Authentication Method set to "Auto-Detect" then this rule will
      change the authentication to match the request identified.
  Solution: This is an informational alert rather than a vulnerability and so there is nothing to
      fix.
  CVE: -
  CWE: -
  References: https://www.zaproxy.org/docs/desktop/addons/authentication-helper/auth-req-id/
  Also Reported As: -
  Composite Score: 0.0

Finding 8
  ID: 8
  Title: Session Management Response Identified
  Severity: Informational
  Confidence: Medium
  Scanners: ZAP
  Affected:
    - http://127.0.0.1:4280/security.php (GET)
    - http://127.0.0.1:4280/login.php (POST)
  Description: The given response has been identified as containing a session management token. The
      'Other Info' field contains a set of header tokens that can be used in the Header Based
      Session Management Method. If the request is in a context which has a Session Management
      Method set to "Auto-Detect" then this rule will change the session management to use the
      tokens identified.
  Solution: This is an informational alert rather than a vulnerability and so there is nothing to
      fix.
  CVE: -
  CWE: -
  References: https://www.zaproxy.org/docs/desktop/addons/authentication-helper/session-mgmt-id/
  Also Reported As: -
  Composite Score: 0.0

Finding 9
  ID: 9
  Title: User Agent Fuzzer
  Severity: Informational
  Confidence: Medium
  Scanners: ZAP
  Affected: http://127.0.0.1:4280/security.php (GET)
  Description: Check for differences in response based on fuzzed User Agent (eg. mobile sites,
      access as a Search Engine Crawler). Compares the response statuscode and the hashcode of the
      response body with the original response.
  Solution: -
  CVE: -
  CWE: -
  References: https://owasp.org/wstg
  Also Reported As: -
  Composite Score: 0.0

Finding 10
  ID: 10
  Title: Suggested security header missing: content-security-policy.
  Severity: -
  Confidence: -
```

```
  Scanners: Nikto
  Affected: localhost:80/ (GET)
  Description: Suggested security header missing: content-security-policy.
  Solution: -
  CVE: -
  CWE: -
  References: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
  Also Reported As: -
  Composite Score: -

Finding 11
  ID: 11
  Title: Suggested security header missing: strict-transport-security.
  Severity: -
  Confidence: -
  Scanners: Nikto
  Affected: localhost:80/ (GET)
  Description: Suggested security header missing: strict-transport-security.
  Solution: -
  CVE: -
  CWE: -
  References: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
  Also Reported As: -
  Composite Score: -

Finding 12
  ID: 12
  Title: Suggested security header missing: permissions-policy.
  Severity: -
  Confidence: -
  Scanners: Nikto
  Affected: localhost:80/ (GET)
  Description: Suggested security header missing: permissions-policy.
  Solution: -
  CVE: -
  CWE: -
  References: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
  Also Reported As: -
  Composite Score: -

Finding 13
  ID: 13
  Title: Suggested security header missing: x-content-type-options.
  Severity: -
  Confidence: -
  Scanners: Nikto
  Affected: localhost:80/ (GET)
  Description: Suggested security header missing: x-content-type-options.
  Solution: -
  CVE: -
  CWE: -
  References: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
  Also Reported As: -
  Composite Score: -

Finding 14
  ID: 14
  Title: Suggested security header missing: referrer-policy.
  Severity: -
  Confidence: -
  Scanners: Nikto
  Affected: localhost:80/ (GET)
  Description: Suggested security header missing: referrer-policy.
  Solution: -
  CVE: -
  CWE: -
  References: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
  Also Reported As: -
  Composite Score: -

Finding 15
  ID: 15
  Title: Apache/2.4.25 appears to be outdated (current is at least 2.4.68).
  Severity: -
  Confidence: -
```

```
  Scanners: Nikto
  Affected: localhost:80/ (HEAD)
  Description: Apache/2.4.25 appears to be outdated (current is at least 2.4.68).
  Solution: -
  CVE: -
  CWE: -
  References: -
  Also Reported As: -
  Composite Score: -

Finding 16
  ID: 16
  Title: Directory indexing found.
  Severity: -
  Confidence: -
  Scanners: Nikto
  Affected:
    - localhost:80/config/ (GET)
    - localhost:80/docs/ (GET)
  Description: Directory indexing found.
  Solution: -
  CVE: -
  CWE: CWE-548
  References: -
  Also Reported As: -
  Composite Score: -

Finding 17
  ID: 17
  Title: Configuration information may be available remotely.
  Severity: -
  Confidence: -
  Scanners: Nikto
  Affected: localhost:80/config/ (GET)
  Description: Configuration information may be available remotely.
  Solution: -
  CVE: -
  CWE: -
  References: -
  Also Reported As: -
  Composite Score: -

Finding 18
  ID: 18
  Title: Apache default file found.
  Severity: -
  Confidence: -
  Scanners: Nikto
  Affected: localhost:80/icons/README (GET)
  Description: Apache default file found.
  Solution: -
  CVE: -
  CWE: -
  References: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
  Also Reported As: -
  Composite Score: -

Finding 19
  ID: 19
  Title: Admin login page/section found.
  Severity: -
  Confidence: -
  Scanners: Nikto
  Affected: localhost:80/login.php (GET)
  Description: Admin login page/section found.
  Solution: -
  CVE: -
  CWE: -
  References: -
  Also Reported As: -
  Composite Score: -

Finding 20
  ID: 20
  Title: .gitignore file found.
```

```
  Severity: -
  Confidence: -
  Scanners: Nikto
  Affected: localhost:80/.gitignore (GET)
  Description: .gitignore file found. It is possible to grasp the directory structure.
  Solution: -
  CVE: -
  CWE: -
  References: -
  Also Reported As: -
  Composite Score: -

Finding 21
  ID: 21
  Title: The X-Content-Type-Options header is not set.
  Severity: -
  Confidence: -
  Scanners: Nikto
  Affected: localhost:80/ (GET)
  Description: The X-Content-Type-Options header is not set. This could allow the user agent to
      render the content of the site in a different fashion to the MIME type.
  Solution: -
  CVE: -
  CWE: -
  References: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-t
      ype-header/
  Also Reported As: -
  Composite Score: -
```